

MEHER SUDHAKAR ABBIREDDI

(240) 340-0064 | msabbi2022@gmail.com | linkedin.com/in/meher-sudhakar | github.com/Mehersudhakar | mehersudhakar.vercel.app

PROFESSIONAL SUMMARY

Cybersecurity engineer with 3+ years across penetration testing, vulnerability exploitation, and adversarial testing of web, API, cloud, and production AI systems. Builds and validates end-to-end attack chains spanning authentication and authorization bypass, privilege escalation, lateral movement, post-exploitation, source-level review for exploitation primitives, and adversarial testing of LLM and RAG pipelines. Surfaced 30+ confirmed vulnerabilities, including a novel Denial-of-Wallet attack class on a production RAG pipeline, a high-severity JWT lifecycle flaw on a multi-tenant SaaS platform, and 25+ critical findings that drove a 35% reduction in production incidents. Certified eJPT, CompTIA Security+, and Certified Ethical Hacker (CEH), currently pursuing OSCP.

PROFESSIONAL EXPERIENCE

Cybertrust America | Cybersecurity Engineer

Jun 2025 – Present

- Strengthened a **multi-tenant SaaS** platform's session security before SOC 2 attestation by surfacing a high-severity **JWT lifecycle flaw** that survived logout, confirmed by replaying tokens in Burp Suite.
- Discovered 4+ high-severity findings in a production **RAG**-based AI application, including a novel **Denial-of-Wallet** attack class and LLM prompt injection, using Burp Suite and custom Python exploit scripts.
- Escalated one prompt-injection entry point into data exfiltration and **privilege escalation** by scripting multi-step PoCs in Python across production LLM orchestration and **identity integration** layers.
- Exposed client-side **information disclosure** in a **SOC 2**-aligned pentest of a production SaaS platform by auditing frontend assets (role-constant enumeration, admin-route references) in browser DevTools.
- Strengthened production LLM systems by designing **adversarial test suites** that proved **guardrail-bypass** paths, with hardening recommendations adopted by client engineering pre-deployment.
- Uncovered prompt-injection entry points, **hardcoded credentials**, and data-leakage vectors through source-level **static analysis** with Snyk across production LLM orchestration and agentic code.
- Accelerated client remediation by delivering penetration-test reports scoped to **CVSS v3** and **OWASP Top 10**, pairing technical PoCs with step-by-step guidance adopted pre-production by engineering stakeholders.

Handshake AI | AI Red Team Engineer (Contract)

Nov 2025 – Mar 2026

- Discovered exploitable model behavior across production AI surfaces through **indirect prompt injection**, **refusal-bypass**, and context-leakage attacks scripted in Python over layered multi-turn prompts.
- Strengthened deployed models by turning confirmed bypasses across 4 attack classes into shipped guardrails, **input filtering**, **output validation**, and response-policy tuning.
- Improved automated risk classifiers by scoring model outputs against **MITRE ATLAS** and **OWASP LLM Top 10** across exploitation, malware, and exfiltration misuse classes.
- Advanced model refusal on dual-use security prompts by authoring **adversarial datasets** paired with harm rationales, shipping **refusal-policy** mitigations across 3 cross-team review cycles.

University of Maryland, College Park | Offensive Security Analyst

Aug 2024 – May 2025

- Exploited **injection**, **broken authentication**, and access-control flaws on production web apps through authenticated and unauthenticated pentests, with working payloads in Burp Suite and sqlmap for owners.
- Escalated access across enterprise **Linux** and **Windows** infrastructure by chaining service misconfigurations and credential exposure into multi-host pivot paths using **Impacket** and **CrackMapExec**.
- Uncovered cloud workload risk across **public-bucket exposure**, IAM misconfiguration, and **over-scoped roles** by auditing IAM policies and CloudTrail logs in production AWS, routing fixes by exploitability.
- Accelerated recurring engagements by building Python automation for **attack-surface enumeration** and **exploit validation**, cutting per-engagement setup time and standardizing reporting output.

DXC Technology | Security Engineer

Jun 2022 – Aug 2023

- Discovered 25+ critical vulnerabilities across web, mobile, and API clients, spanning injection, **broken access control** (IDOR), and **authentication bypass**, contributing to a 35% reduction in production incidents.
- Escalated domain privileges across enterprise test **Active Directory** environments by enumerating attack paths with **BloodHound** and **Kerberoasting** and extracting credentials with Mimikatz.
- Compromised user-awareness and email-security controls through **phishing** simulations and pretext payloads in recurring red-team **social engineering** campaigns using **GoPhish** and Evilginx.

- Reduced critical-vulnerability detection-to-fix time 30% by running threat-emulation drills across 100+ Linux and Windows systems with **Nessus**, prioritizing remediation by **CVSS** score and exploitability.

Verzeo | Web Application Penetration Tester

Oct 2021 – Jun 2022

- Exploited **SQL injection**, **XSS**, and **IDOR** on production web targets, proving each end-to-end with hand-crafted payloads in **OWASP ZAP** and sqlmap, driving risk-prioritized remediation.
- Identified **input-validation**, authentication, and authorization flaws that dynamic scanners missed through manual **source code review** with **SonarQube** across high-risk production modules.
- Reduced manual enumeration effort 30% by automating **reconnaissance** and **attack-surface mapping** with Nmap and custom Python tooling, expanding coverage across components and backend services.

PROJECTS

Pentigo - Autonomous AI Penetration Testing Platform

- Built a multi-agent orchestration system that autonomously chains reconnaissance, scanning, enumeration, exploitation, and post-exploitation, each phase gated on prior findings to mirror how a human pentester scopes follow-up testing.
- Integrated **Nmap**, **Metasploit**, sqlmap, and ffuf through a unified tool-calling layer built in **Python**, passing findings between phases to trigger context-aware follow-up probes against intentionally vulnerable targets.

ReconX - Modular Reconnaissance Automation Framework

- Built a framework automating **subdomain enumeration**, port scanning, **service fingerprinting**, and HTTP probing across attack-surface engagements, normalizing heterogeneous tool output into a structured schema for analysis.
- Implemented configurable scan profiles with **Shodan** and **ffuf** integrations and per-module rate limiting to evade **WAF** and IDS detection during early-phase recon, keeping per-engagement scoping flexible.

Securing a Cloud-Based Healthcare Application

- Diagnosed architectural security gaps and implemented security-by-design controls across a **HIPAA**-aligned **AWS** environment, mitigating 80% of vulnerabilities and misconfigurations through risk-prioritized remediation.
- Refined **IAM** policies, enforced MFA on privileged accounts, and applied least-privilege controls per role and service, reducing excessive permissions 40% with **KMS**-managed encryption and **CloudTrail** audit logging.

SKILLS

Penetration Testing & Offensive Security: Manual web application and API exploitation, network penetration testing, authentication and authorization bypass (OAuth 2.0, OIDC, JWT, SAML), exploit chains, exploit development, privilege escalation, lateral movement, attack-surface enumeration, post-exploitation, social engineering, phishing simulation, bug bounty / responsible disclosure

AI Red Team & LLM Security: Prompt injection (direct and indirect), Denial-of-Wallet attack design, multi-step LLM exploit chaining, jailbreak taxonomy, guardrail-bypass testing, RAG pipeline attack surface, agentic access-control bypass, adversarial test design, OWASP LLM Top 10, MITRE ATLAS

Application & Code-Level Security: Manual source code review, STRIDE threat modeling, SAST/DAST/SCA integration, CI/CD security gates, attack-surface analysis, vulnerability triage, OWASP Top 10, OWASP API Security Top 10

Programming & Scripting: Python, JavaScript, PowerShell, Bash, Unix Shell, C, C++, SQL, exploit scripting, automation tooling, JSON schema design

Security Tools: Burp Suite, Nmap, Nessus, Metasploit, sqlmap, ffuf, BloodHound, Mimikatz, Wireshark, SonarQube, Veracode, Checkmarx

Cloud, Infrastructure & Standards: AWS (IAM, S3, EC2, Lambda assessment), Active Directory, Docker, Linux (Kali, Ubuntu), Windows Server, CI/CD (Jenkins, GitHub Actions), MITRE ATT&CK, NIST CSF, CVSS v3, SOC 2, PCI DSS, HIPAA

CERTIFICATIONS

- Offensive Security Certified Professional (OSCP) – Offensive Security (Pursuing)
- Junior Penetration Tester (eJPT) – INE
- CompTIA Security+ – CompTIA
- Certified Ethical Hacker (CEH) – EC-Council

EDUCATION

University of Maryland, College Park | Master of Engineering, Cybersecurity

Aug 2023 – May 2025

Coursework: Reverse Engineering, Hacking of C Programs & Unix Binaries, Cryptography, Cloud Security, Digital Forensics, Network Security.